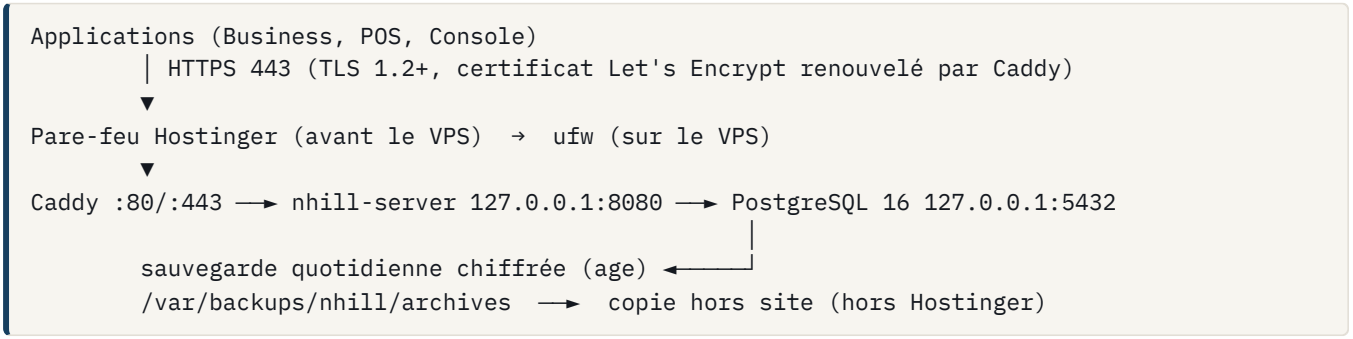
Déploiement de Nhill Server sur un VPS Hostinger (France)

English: ../en/vps-deployment-hostinger.md

Ce guide installe Nhill Server et sa base PostgreSQL sur **un VPS Hostinger situé en France**, système Ubuntu 24.04, puis décrit l'exploitation : sauvegardes, restauration, surveillance, mises à jour et retour arrière. Les commandes s'exécutent sur le VPS, sauf mention contraire.

> **État de vérification (28 octobre 2026).** La procédure complète (`deploy/vps/provision.sh` puis `deploy/vps/tests/acceptance.sh`) est exécutée par le job CI `vps-test` sur une machine Ubuntu 24.04 neuve, avec un certificat de l'autorité locale de Caddy. Elle n'a **pas** encore été exécutée sur le VPS Hostinger de production, ni avec un certificat Let's Encrypt réel : faites-le d'abord sur un VPS de recette.

1. Architecture retenue



Choix	Raison
Un seul VPS, base locale	volume de départ modeste ; la base n'est jamais exposée au réseau (écoute sur 127.0.0.1 et ::1 seulement)
Caddy devant l'API	TLS automatique (ACME), en-têtes de sécurité, limite de taille des requêtes ; l'API n'écoute qu'en local
Rôles PostgreSQL séparés	`nhill_owner` (migrations), `nhill_app` (API, sans contournement de la sécurité par ligne), `nhill_backup` (lecture seule)
Sauvegardes chiffrées par `age`	seule la clé **publique** est sur le VPS : un vol du VPS ou des sauvegardes ne révèle pas les données
Copie de la base avant chaque mise à jour	retour arrière en une commande, sans la clé privée de sauvegarde
Données en France (Union européenne)	localisation choisie à la création du VPS ; elle ne peut plus changer ensuite

Hébergeur. Pour un client établi en RDC, l'entité contractante d'Hostinger est Hostinger International Ltd, 61 Lordou Vironos str., 6023 Larnaca, Chypre (conditions générales d'Hostinger, § 2, et leur liste de pays). Hostinger propose un accord de traitement des données (DPA) qui liste ses sous-traitants ; l'accepter et le conserver fait partie du dossier de conformité (registre des traitements, modèle juridique 18).

2. Ports, flux et pare-feu

Port	Qui écoute	Ouvert sur Internet	Rôle
22/tcp (ou votre port SSH)	sshd	oui, de préférence limité à vos adresses	administration (clés SSH)
80/tcp	Caddy	oui	défi ACME de Let's Encrypt, redirection vers HTTPS
443/tcp, 443/udp	Caddy	oui	API en HTTPS (HTTP/2, HTTP/3)
8080/tcp	nhill-server	**non** (127.0.0.1)	API derrière Caddy
5432/tcp	PostgreSQL	**non** (127.0.0.1, ::1)	base de données

Deux pare-feu, complémentaires :

1. **Pare-feu géré d'Hostinger** (panneau du VPS → *Security* → *Firewall*). Il filtre avant que le trafic n'atteigne le VPS ; un groupe de règles vide **bloque tout**. Créez un groupe avec des règles « accept » pour 22/tcp (source : vos adresses si possible), 80/tcp, 443/tcp et 443/udp, puis activez-le. Les modifications s'appliquent aux nouvelles connexions en deux minutes au plus.
2. **ufw sur le VPS**, configuré par `provision.sh` : tout est refusé en entrée sauf SSH (avec limitation de débit), 80/tcp et 443/tcp+udp. `fail2ban` bannit une heure une adresse après 5 échecs SSH en 10 minutes.

3. Avant de commencer

1. **Créer le VPS** chez Hostinger : emplacement **France**, système **Ubuntu 24.04** « plain OS » (sans panneau), 2 vCPU et 4 Go de RAM recommandés (2 Go minimum), une clé SSH ajoutée à la création.
2. **DNS** : un enregistrement `A` (et `AAAA` si le VPS a une adresse IPv6) pour le nom de l'API, par exemple `api.<votre-domaine>`, vers l'adresse du VPS. Le certificat n'est délivré qu'une fois ce nom résolu vers le VPS.
3. **Clé de sauvegarde, sur votre poste** (jamais sur le VPS) : `age-keygen -o nhill-backup-key.txt` ; notez la clé publique affichée (`age1…`) ; rangez le fichier dans votre coffre de mots de passe et une copie hors ligne. Sans lui, aucune sauvegarde ne peut être relue.
4. **Paquet** : `nhill-server_<version>-1_amd64.deb` et son `SHA256SUMS` (`dist/linux/ubuntu-24.04/` ou la livraison), plus le dossier `deploy/vps/` du dépôt (aussi installé par le paquet dans `/usr/share/nhill/vps/`).
5. **Copie hors site** (recommandée) : un espace de stockage hors d'Hostinger, dans l'Union européenne, et une commande de copie (par exemple `rclone` configuré pour l'utilisateur `nhill-backup`).

4. Installation

```
scp -r nhill-server_3.0.0-1_amd64.deb SHA256SUMS deploy/vps root@<adresse-du-vps>:/root/
ssh root@<adresse-du-vps>
cd /root && sudo ./vps/provision.sh \
  --deb nhill-server_3.0.0-1_amd64.deb --sha256sums SHA256SUMS \
  --api-domain api.<votre-domaine> --acme-email <adresse-pour-les-avis-de-certificat> \
  --admin-email <votre-adresse> --admin-name "<Votre nom>" \
  --backup-recipient age1… \
  --support-email support@nhill.online \
  --offsite-cmd 'rclone copy {} distant:nhill-sauvegardes/' \
  --harden-ssh
```

Le script s'arrête à la première erreur ; relancé, il conserve ce qui est installé. Il :

1. vérifie le système (Ubuntu 24.04, amd64, mémoire, disque) et **l'empreinte SHA-256 du paquet** ;

2. installe depuis les dépôts Ubuntu : PostgreSQL 16, Caddy, age, ufw, fail2ban et les mises à jour de sécurité automatiques (sans redémarrage automatique) ;
3. configure ufw et fail2ban ; avec `--harden-ssh`, n'accepte plus que les clés SSH (ignoré tant qu'aucune clé n'est installée, pour ne pas vous enfermer dehors) ;
4. restreint PostgreSQL à la boucle locale et crée la base `nhill` ;
5. installe le paquet, puis la base avec `nhill-server setup` au moyen d'un super-utilisateur temporaire **supprimé aussitôt** (son mot de passe ne passe que par l'entrée standard) ; contrôle l'isolation (10 vérifications) ;
6. configure les sauvegardes chiffrées et en fait une première ;
7. écrit `/etc/caddy/Caddyfile` pour `api.<votre-domaine>` (Let's Encrypt) ;
8. installe les contrôles de santé, la rétention des journaux et les outils `nhill-update`, `nhill-rollback` ;
9. affiche le **jeton à usage unique** du premier administrateur de Nhill Console (30 minutes).

Ensuite :

- **Sauvegardez `NH_SECRET_KEY`** (`sudo grep '^NH_SECRET_KEY=' /etc/nhill/server.env`) dans votre coffre, à part des sauvegardes : sans elle, les codes d'établissement et les seconds facteurs des administrateurs ne sont plus lisibles.
- **Nhill Console** : adresse `https://api.<votre-domaine>`, « Premier accès », jeton, mot de passe (14 caractères minimum) et TOTP. Jeton expiré ou perdu, tant que personne n'a terminé le premier accès : `sudo -u nhill nhill-server --config /etc/nhill/server.env admin-bootstrap <même-adresse> "<Nom>"`.
- **E-mails** : renseignez le relais SMTP (`NH_EMAIL_TRANSPORT=smtp`, `NH_SMTP_*`, guide de configuration) avec une adresse d'expédition du domaine autorisée par SPF et DKIM, puis `sudo systemctl restart nhill-server`. Tant que `NH_EMAIL_TRANSPORT=log`, aucun e-mail (codes de récupération, rappels) n'est envoyé.

5. Secrets

Secret	Où	Droits	Sauvegarde
`NH_SECRET_KEY` (clé maîtresse)	`/etc/nhill/server.env`	600, `nhill`	coffre de mots de passe, à part
Mots de passe `nhill_owner`, `nhill_app`	`/etc/nhill/server.env`	600, `nhill`	non nécessaire (régénérables par `nhill-server setup`)
Mot de passe `nhill_backup`	`/var/backups/nhill/.pgpass`	600, `nhill-backup`	non nécessaire
Clé **publique** age	`/etc/nhill/backup.env`	600, `nhill-backup`	—
Clé **privée** age	**hors du VPS**	—	coffre + copie hors ligne
Mot de passe SMTP	`/etc/nhill/smtp-password` (`NH_SMTP_PASSWORD_FILE`)	600, `nhill`	coffre
Secrets des prestataires de paiement	base, chiffrés par `NH_SECRET_KEY`	—	sauvegardes

Aucun secret n'est dans le dépôt, dans le paquet ni dans les journaux.

6. Certificats

Caddy obtient le certificat de `api.<votre-domaine>` auprès de Let's Encrypt (défi HTTP-01 sur le port 80) et le renouvelle seul, environ 30 jours avant l'échéance. Le contrôle de santé alerte s'il reste moins de 14 jours. En cas d'échec : `journalctl -u caddy`, résolution DNS du nom, ports 80 et 443 ouverts dans **les deux** pare-feu.

7. Sauvegardes

Niveau	Fréquence	Conservation	Ce que cela protège
Sauvegarde Nhill chiffrée (`nhill-backup.timer`)	chaque jour vers 02:30 UTC (+0 à 15 min)	14 jours sur le VPS	erreurs, suppression, corruption de la base
Copie hors site (`NH_BACKUP_OFFSITE_CMD`)	à chaque sauvegarde	selon votre stockage (au moins 30 jours conseillés)	perte du VPS ou du compte Hostinger
Sauvegardes Hostinger du VPS entier	hebdomadaire par défaut ; quotidienne en option payante ; 2 hebdomadaires et 2 quotidiennes conservées	—	reprise du système complet ; **une restauration écrase tout le VPS**
Instantané Hostinger	à la demande (avant une mise à jour)	un seul, supprimé après 1 jour	retour du système entier juste après une opération
Copie de la base avant mise à jour (`nhill_pre_…`)	à chaque `nhill-update`	les 2 dernières	retour arrière d'une mise à jour

Faits Hostinger tirés de son article d'assistance « How to back up or restore a VPS », consulté le 28 octobre 2026. Les sauvegardes Hostinger **complètent** les sauvegardes Nhill sans les remplacer : elles ne sont ni chiffrées par vous, ni conservées hors d'Hostinger.

Vérifier : `systemctl list-timers nhill-backup.timer`, `ls -lh /var/backups/nhill/archives`, `journalctl -u nhill-backup`.

8. Restauration

Test mensuel, hors du VPS (poste d'administration ou VPS de recette, avec la clé privée) :

```
scp root@<vps>:/var/backups/nhill/archives/nhill-<date>.dump.age* .
deploy/vps/nhill-restore-test.sh nhill-<date>.dump.age nhill-backup-key.txt
```

Le script démarre un PostgreSQL jetable (socket local, rien sur le réseau), restaure, compte migrations, établissements, utilisateurs, documents et journal d'audit, vérifie la sécurité par ligne forcée et l'isolation du rôle applicatif, puis efface tout.

Restauration réelle sur le VPS (après une perte de données) :

1. Copier la sauvegarde (avec son `.sha256`) et, **temporairement**, la clé privée dans `/var/lib/postgresql/restauration/` (propriétaire `postgres`, droits 700).
2. `cd /var/lib/postgresql/restauration && sudo -u postgres env PGHOST=/var/run/postgresql nhill-restore.sh nhill-<date>.dump.age cle.txt nhill_restauree` (restaure dans une **nouvelle** base, puis l'affiche : migrations, établissements, sécurité par ligne).

3. `sudo systemctl stop nhill-server`, puis renommer : `ALTER DATABASE nhill RENAME TO nhill_avant_restauration; ALTER DATABASE nhill_restauree RENAME TO nhill;` et redonner les droits de base : `GRANT CONNECT, CREATE ON DATABASE nhill TO nhill_owner; GRANT CONNECT ON DATABASE nhill TO nhill_app, nhill_backup;`
4. `sudo systemctl start nhill-server`, contrôler `nhill-healthcheck`, puis **supprimer la clé privée du VPS** (`sudo shred -u /var/lib/postgresql/restauration/cle.txt`).

Les données saisies entre la sauvegarde et l'incident sont perdues : la perte maximale est d'un jour avec la fréquence par défaut.

9. Surveillance et journaux

`nhill-healthcheck.timer` vérifie toutes les 5 minutes : services `nhill-server`, `postgresql`, `caddy` ; `/health` en local et en HTTPS par Caddy ; échéance du certificat ; ports 5432 et 8080 en local seulement ; ufw actif ; disque (< 85 %) ; dernière sauvegarde de moins de 26 heures. Résultat : `/var/lib/nhill/health.json`. Un échec démarre `nhill-alert` : message dans le journal système (priorité `err`) et, si `NH_ALERT_CMD` est renseignée dans `/etc/nhill/alert.env`, votre commande d'alerte (e-mail, messagerie, notification).

Un VPS ne peut pas signaler sa propre panne totale : ajoutez une **sonde externe** sur `https://api.<votre-domaine>/health` (service de surveillance de disponibilité de votre choix).

Journal	Où	Conservation
API (JSON par ligne)	`journalctl -u nhill-server`	90 jours, 1 Go au plus (journald)
Accès HTTPS (adresses IP)	`/var/log/caddy/nhill-access.log`	10 × 50 Mo, 90 jours au plus
PostgreSQL	`/var/log/postgresql/`	rotation Ubuntu (logrotate)
Sauvegardes, santé	`journalctl -u nhill-backup -u nhill-healthcheck`	90 jours
Erreurs des applications	Nhill Console → Erreurs techniques	base

10. Mises à jour et retour arrière

```
sudo nhill-update nhill-server_3.0.1-1_amd64.deb --sha256sums SHA256SUMS
```

1. vérifie le paquet (nom, empreinte, version plus récente) ;
2. fait une sauvegarde chiffrée (et sa copie hors site) ;
3. arrête l'API et copie la base (`nhill_pre_<version>_<date>`) ;
4. installe le paquet ; au démarrage, le serveur applique les nouvelles migrations ;
5. attend `/health` ; en cas d'échec, **retour arrière automatique**.

Interruption : de l'étape 3 à la fin de l'étape 5, en général moins d'une minute pour une petite base. Avant une mise à jour importante, prenez aussi un **instantané Hostinger**.

Retour arrière manuel (par exemple après un défaut constaté plus tard) : `sudo nhill-rollback` réinstalle le paquet précédent et la copie de la base ; la base utilisée depuis la mise à jour est conservée sous `nhill_failed_<date>` (les saisies faites depuis s'y trouvent).

Migrations : versionnées (`db/migrations/NNNN_*.sql`), appliquées dans l'ordre, une transaction chacune, sous verrou ; une migration modifiée après application est refusée (empreinte). Elles ne vont que vers l'avant : un serveur plus ancien **refuse de démarrer** sur une base migrée par une version plus récente (message dans `journalctl -u nhill-server`) ; on revient donc en arrière avec la copie de la base, jamais en « démigrant ».

Mises à jour du système : automatiques pour les correctifs de sécurité ; redémarrage à planifier quand `/var/run/reboot-required` existe (`sudo reboot`, l'API redémarre seule).

11. Réinstallation sur un VPS neuf (plan de reprise)

1. Créer un VPS (France, Ubuntu 24.04), DNS, pare-feu Hostinger : §§ 2-3.
2. Lancer `provision.sh` (§ 4) avec le même domaine.
3. Remettre `NH_SECRET_KEY` d'origine dans `/etc/nhill/server.env` (coffre), puis restaurer la dernière sauvegarde hors site (§ 8, restauration réelle).
4. `sudo systemctl restart nhill-server`, `nhill-healthcheck`, connexion d'essai depuis Nhill Console et Nhill Business.

12. Données personnelles et conformité

- Les données des établissements et de leurs clients sont hébergées en France, dans l'Union européenne ; le contrat et le DPA d'Hostinger encadrent ce sous-traitant.
- Les établissements situés hors de l'Union européenne (par exemple en RDC) transfèrent leurs données vers la France : les obligations de leur pays (déclaration, autorisation de transfert) sont recensées dans `docs/fr/parametres-legaux.md` et `legal/fr/00-recherche-juridique.md`. Aucune conformité n'est déclarée sans vérification par un juriste.
- Rétention des journaux limitée (90 jours) ; sauvegardes chiffrées ; accès au VPS par clé SSH.

13. Ce qui reste à faire par l'exploitant

Action	Où
Accepter le DPA d'Hostinger et l'archiver	compte Hostinger
Configurer le pare-feu Hostinger	panneau du VPS
Choisir et configurer la copie hors site	`--offsite-cmd`, `rclone`
Configurer le relais SMTP et SPF/DKIM/DMARC du domaine d'expédition	`server.env`, zone DNS
Ajouter une sonde de disponibilité externe	service de votre choix
Renseigner `NH_ALERT_CMD`	`/etc/nhill/alert.env`
Exécuter le premier test de restauration hors du VPS, puis chaque mois	§ 8